Practical Vulnerability Assessment Report

Course: GRC102 - Practical Vulnerability Assessment for GRC Professionals
Student: Jackline Maina
Date: 24 October 2026
Target System: Metasploitable
Assessment Type: Internal Vulnerability Assessment

Contents

1. Executive Summary 3

2. Methodology 3

3. Technical Findings 8

4. Risk Assessment Table 8

5. Compliance Analysis 9

6. Recommendations 10

7. Conclusion 10

1. Executive Summary

Objective

The objective of this assessment was to identify security vulnerabilities on the Metasploitable server, evaluate the associated business risks, and assess compliance with relevant security frameworks including NIST CSF, CIS Controls, and PCI DSS.

Overall Assessment

The assessment identified multiple high-risk vulnerabilities, including outdated software, insecure network services, weak authentication controls, and known exploitable vulnerabilities. These weaknesses significantly increase the likelihood of unauthorized access, data compromise, and disruption of services.

Overall Risk Rating: HIGH

Key Risks

- FTP service vulnerable to known backdoor attacks.
- Telnet and FTP transmit credentials in plaintext.
- Weak/default credentials increase unauthorized access risks.
- Multiple outdated services expose the system to known exploits.
- Excessive open ports increase the attack surface.

2. Methodology

The assessment was conducted using industry-standard security tools.

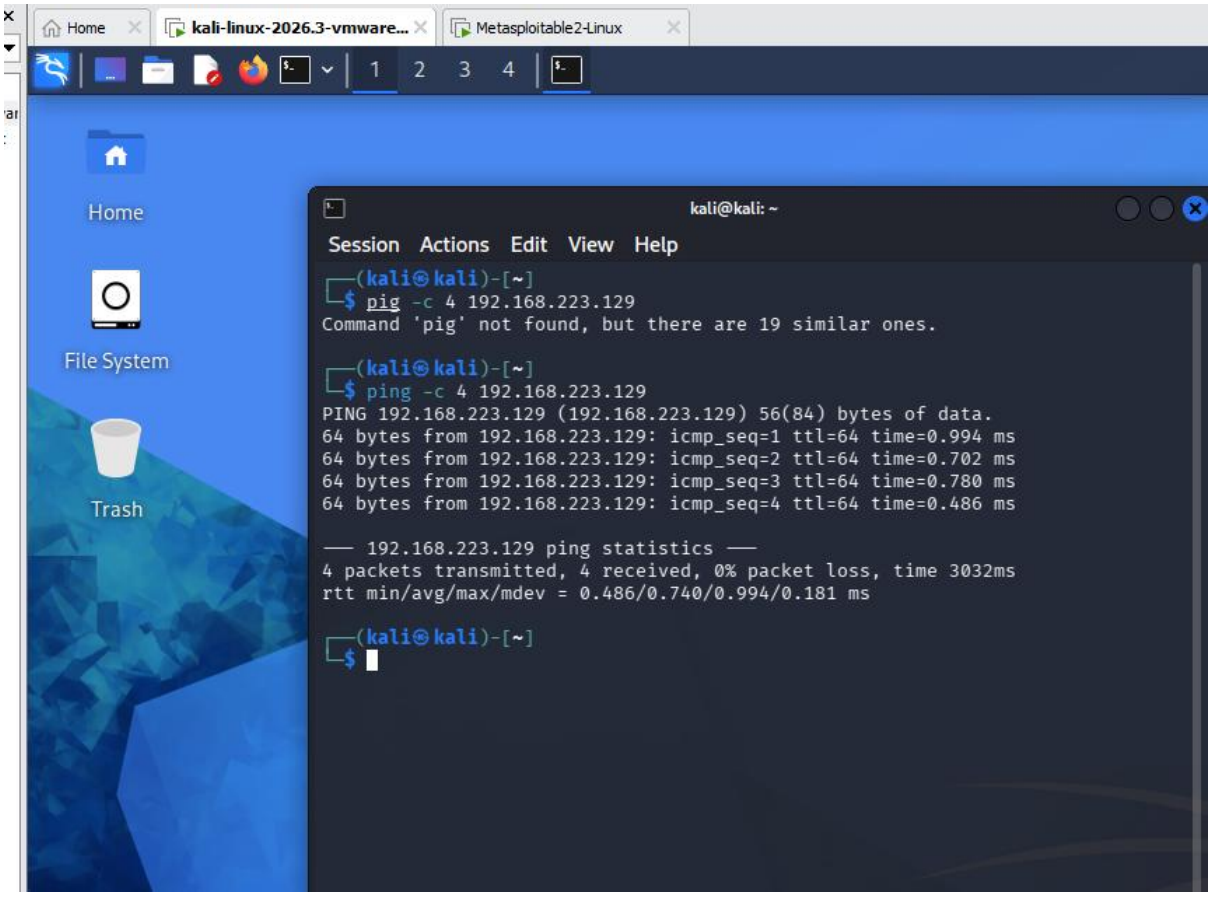
Tools Used

- Nmap
- Nikto
- Nuclei
- xsltproc

Activities Performed

Asset Discovery

ping -c 4 192.168.223.129



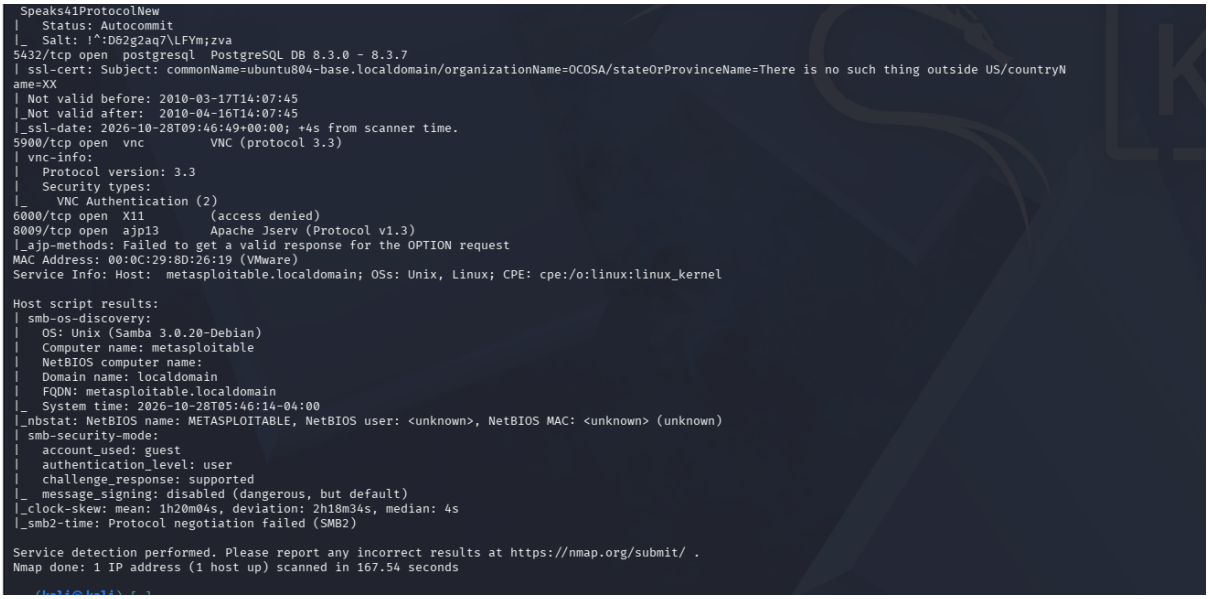
Port and Service Enumeration

nmap -sV -sC -O -p- -oA initial_scan 192.168.223.129



```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC -F -T3 -oX initial_scan.xml 192.168.223.129

Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-28 05:45 -0400
Nmap scan report for 192.168.223.129
Host is up (0.0031s latency).
Not shown: 82 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.223.130
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_    SSL2_RC4_128_WITH_MD5
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      37473/tcp   mountd
|   100005  1,2,3      57510/udp   mountd
|   100021  1,3,4      43116/udp   nlockmgr
|   100021  1,3,4      51585/tcp   nlockmgr
|   100024  1          53960/tcp   status
|_  100024  1          58659/udp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: SupportsCompression, SupportsTransactions, Support41Auth, LongColumnFlag, ConnectWithDatabase, SwitchToSSLAfterHandshake,
 Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: !^:D82g2aq7\LFYm;zva
```

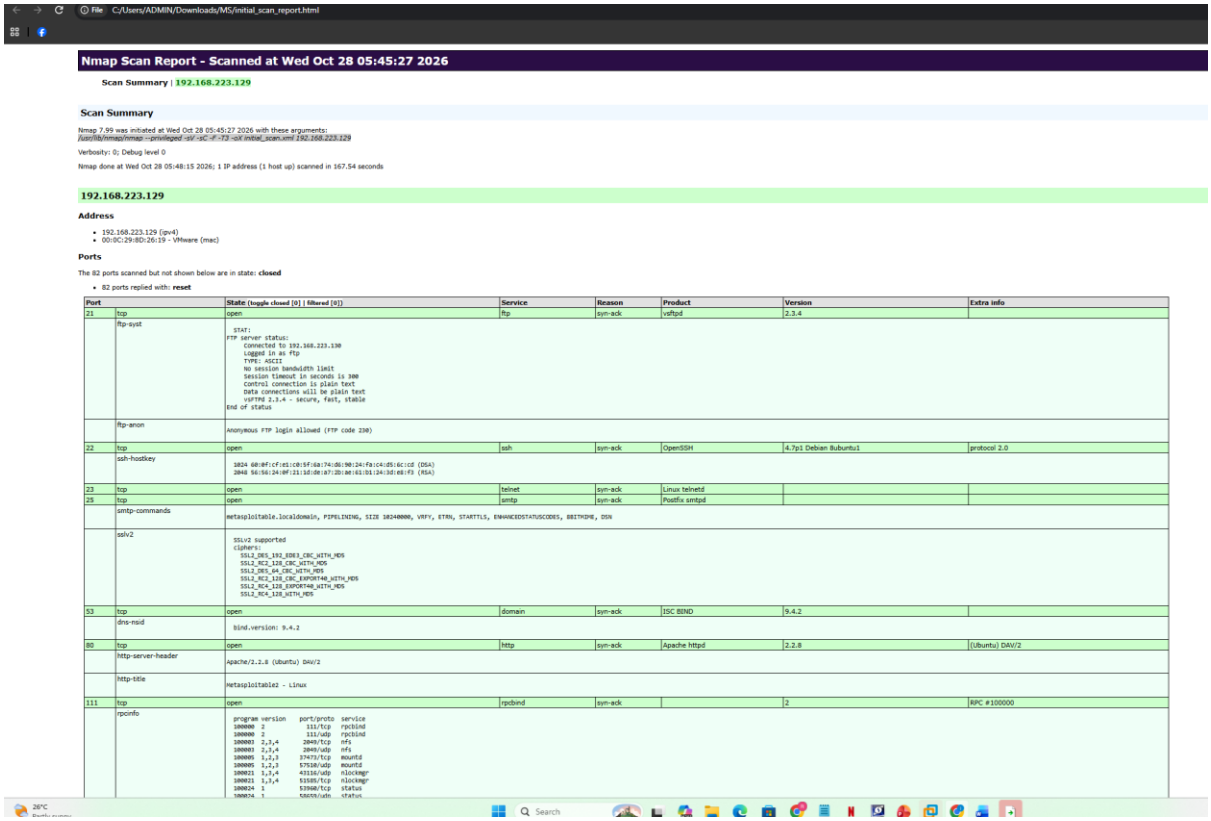


Significance of Open Ports

Open ports represent active services that may introduce security risks if improperly configured or unnecessary. Services such as FTP (21) and Telnet (23) increase the attack surface and may expose credentials and sensitive data through insecure communication channels. Identifying exposed services supports attack surface reduction and secure configuration management requirements under CIS Controls and NIST CSF. Failure to manage unnecessary services may result in increased risk of unauthorized access and non-compliance with organizational security standards.

HTML Report Generation

xsltproc -o initial_scan_report.html /usr/share/nmap/nmap.xsl initial_scan.xml



Nmap Scan Report - Scanned at Wed Oct 28 05:45:27 2026

Scan Summary | 192.168.223.129

Scan Summary

Nmap 7.99 was initiated at Wed Oct 28 05:45:27 2026 with these arguments:
/usr/lib/nmap/nmap --privileged -sV -sC -F -T3 -oX initial_scan.xml 192.168.223.129

Verbosity: 0; Debug level 0

Nmap done at Wed Oct 28 05:48:15 2026; 1 IP address (1 host up) scanned in 167.54 seconds

192.168.223.129

Address

- 192.168.223.129 (ipv4)
- 00:0C:29:8D:26:19 - VMware (mac)

Ports

The 82 ports scanned but not shown below are in state: closed

- 82 ports replied with: reset

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
	ftp-syst	STAT: FTP server status: Connected to 192.168.223.130 Logged in as ftp TYPE: ASCII No session bandwidth limit Session timeout in seconds is 300 Control connection is plain text Data connections will be plain text vsFTPd 2.3.4 - secure, fast, stable End of status					
	ftp-anon	Anonymous FTP login allowed (FTP code 230)					
22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
	ssh-hostkey	1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)					
23	tcp	open	telnet	syn-ack	Linux telnetd		
25	tcp	open	smtp	syn-ack	Postfix smtpd		
	smtp-commands	metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN					
	sslv2	SSLv2 supported ciphers: SSL2_DES_192_EDE3_CBC_WITH_MD5 SSL2_RC2_128_CBC_WITH_MD5 SSL2_DES_64_CBC_WITH_MD5 SSL2_RC2_128_CBC_EXPORT40_WITH_MD5 SSL2_RC4_128_EXPORT40_WITH_MD5 SSL2_RC4_128_WITH_MD5					
53	tcp	open	domain	syn-ack	ISC BIND	9.4.2	
	dns-nsid	bind.version: 9.4.2					
80	tcp	open	http	syn-ack	Apache httpd	2.2.8	(Ubuntu) DAV/2
	http-server-header	Apache/2.2.8 (Ubuntu) DAV/2					
	http-title	Metasploitable2 - Linux					
111	tcp	open	rpcbind	syn-ack		2	RPC #100000
	rpcinfo	program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 37473/tcp mountd 100005 1,2,3 57510/udp mountd 100021 1,3,4 43116/udp nlockmgr 100021 1,3,4 53585/tcp nlockmgr 100024 1 53940/tcp status 100024 1 58659/udp status					

Web Vulnerability Assessment

nikto -h http:// 192.168.223.129 -o nikto_scan.txt



```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://192.168.223.129 -o nikto_scan.txt
- Nikto v2.6.1
---------------------------------------------------------------------------
+ Target IP:          192.168.223.129
+ Target Hostname:    192.168.223.129
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-10-28 05:47:57 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates:
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8235 requests: 0 errors and 11 items reported on the remote host
+ End Time:           2026-10-28 05:48:48 (GMT-4) (51 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

┌──(kali㉿kali)-[~]
└─$
```

Vulnerability Scanning

nuclei -u http://192.168.223.129 -o nuclei_web_scan.txt

nuclei -target 192.168.223.129 -o nuclei_full_scan.txt

3. Technical Findings

Open Ports and Services

Port	Service	Version
21	FTP	vsFTPd 2.3.4
22	SSH	OpenSSH 4.7p1
23	Telnet	Telnet
25	SMTP	Postfix
80	HTTP	Apache 2.2.8
139	NetBIOS	Samba
445	SMB	Samba 3.0.20
3306	MySQL	MySQL 5.0.51a
5432	PostgreSQL	PostgreSQL 8.3

Screenshot 1

Insert Nmap HTML Report Screenshot here.

Screenshot 2

Insert Nikto Scan Screenshot here.

Screenshot 3

Insert Nuclei Scan Screenshot here.

4. Risk Assessment Table

Finding	Affected Service	CVE / Reference	Risk	Compliance Mapping	Business Impact
Backdoored FTP Service	FTP	CVE-2011-2523	High	CIS 7.1	Full system compromise

Finding	Affected Service	CVE / Reference	Risk	Compliance Mapping	Business Impact
Unencrypted Communications	Telnet, FTP	N/A	High	NIST CSF PR.DS-2	Credential theft
Weak Passwords	Multiple Services	N/A	High	CIS 5.2	Unauthorized access
Outdated Apache Server	HTTP	Multiple CVEs	Medium	PCI DSS 6.2	Web application compromise
Vulnerable Samba Service	SMB	CVE-2007-2447	High	CIS 7.1	Remote code execution
Excessive Open Ports	Multiple	N/A	Medium	CIS 9	Expanded attack surface
Banner Information Disclosure	HTTP	N/A	Low	CIS 4	Reconnaissance information leakage
Outdated SSH Service	SSH	Multiple CVEs	Medium	NIST PR.IP-12	Increased attack risk

5. Compliance Analysis

Control Framework	Requirement	Status
CIS Control 7	Continuous Vulnerability Management	Non-Compliant
CIS Control 5	Account Management	Non-Compliant
CIS Control 9	Service Configuration Management	Non-Compliant
NIST CSF PR.AC-1	Identity Management	Non-Compliant
NIST CSF PR.DS-2	Data Protection	Non-Compliant
PCI DSS 6.2	Secure Systems & Applications	Non-Compliant

6. Recommendations

Immediate Actions

1. Isolate the server from the network.
2. Patch or remove vulnerable services.
3. Disable FTP and Telnet.
4. Change all default credentials.

Short-Term Actions

1. Upgrade Apache, Samba, SSH, MySQL, and PostgreSQL.
2. Implement secure configuration baselines.
3. Restrict unnecessary network services.

Long-Term Actions

1. Establish a formal vulnerability management program.
2. Conduct routine vulnerability scans.
3. Adopt CIS Benchmarks for system hardening.
4. Track remediation activities through a risk register.

7. Conclusion

The assessment identified several critical and high-risk vulnerabilities that significantly weaken the security posture of the Metasploitable server. The presence of vulnerable services, weak authentication mechanisms, and insecure protocols increases the likelihood of unauthorized access and system compromise. Immediate remediation and alignment with CIS Controls, NIST CSF, and PCI DSS requirements are recommended to reduce organizational risk.